

Data leak worksheet

Incident summary: A sales manager shared access to a folder of internal-only documents with their team during a meeting. The folder contained files associated with a new product that has not been publicly announced. It also included customer analytics and promotional materials. After the meeting, the manager did not revoke access to the internal folder, but warned the team to wait for approval before sharing the promotional materials with others.

During a video call with a business partner, a member of the sales team forgot the warning from their manager. The sales representative intended to share a link to the promotional materials so that the business partner could circulate the materials to their customers. However, the sales representative accidentally shared a link to the internal folder instead. Later, the business partner posted the link on their company's social media page assuming that it was the promotional materials.

Control	Least privilege
Issue(s)	<i>The factors that contributed to the leak are the managers carelessness to provide access to all the confidential files from a folder to an employee who should not have access to it. As well as lack of foresight to not revoke their access privileges.</i> <i>Also how the employee with access to the confidential information shared the whole folder instead of the single file containing the necessary information.</i>
Review	<i>The NIST SP 800-53: AC -6 addresses the principle of least privilege and its control mechanisms. It only allows for the minimal access and authorization required to complete a task or function should be provided to users. And processes, user accounts, and roles should be enforced as necessary to achieve least privilege. The intention is to prevent a user from operating at</i>

	privilege levels higher than what is necessary to accomplish business objectives.
Recommendation(s)	<i>It can be applied by restricting access to sensitive resources based on user role. Automatically revoking access to information after a period of time. Keep activity logs of provisioned user accounts. Regularly audit user privileges to ensure the permissions are up to date.</i>
Justification	<i>These will improve the issue by preventing unauthorized access to confidential files. As well as if shared links to internal files are restricted to employees only. Also, requiring managers and security teams to regularly audit access to team files would help limit the exposure of sensitive information.</i>

Security plan snapshot

The NIST Cybersecurity Framework (CSF) uses a hierarchical, tree-like structure to organize information. From left to right, it describes a broad security function, then becomes more specific as it branches out to a category, subcategory, and individual security controls.

Function	Category	Subcategory	Reference(s)
Protect	PR.DS: <i>Data security</i>	PR.DS-5: <i>Protections against data leaks.</i>	NIST SP 800-53: AC-6

In this example, the implemented controls that are used by the manufacturer to protect against data leaks are defined in NIST SP 800-53—a set of guidelines for securing the privacy of information systems.

Note: References are commonly hyperlinked to the guidelines or regulations they relate to. This makes it easy to learn more about how a particular control should be implemented. It's common to find multiple links to different sources in the references columns.

NIST SP 800-53: AC-6

NIST developed SP 800-53 to provide businesses with a customizable information privacy plan. It's a comprehensive resource that describes a wide range of control categories. Each control provides a few key pieces of information:

- **Control:** A definition of the security control.
- **Discussion:** A description of how the control should be implemented.
- **Control enhancements:** A list of suggestions to improve the effectiveness of the control.

AC-6	Least Privilege
	Control: Only the minimal access and authorization required to complete a task or function should be provided to users.
	Discussion: Processes, user accounts, and roles should be enforced as necessary to achieve least privilege. The intention is to prevent a user from operating at privilege levels higher than what is necessary to accomplish business objectives.
	Control enhancements: ● Restrict access to sensitive resources based on user role. ● Automatically revoke access to information after a period of time. ● Keep activity logs of provisioned user accounts. ● Regularly audit user privileges.

Note: In the category of access controls, SP 800-53 lists least privilege sixth, i.e. AC-6.

Issues

Many people neglected to keep the confidential information private. The manager should have done a better job keeping track of the internal folder by limiting access to the representative and themselves. The customer also could have done a better job of communicating their plans to share the marketing information before posting it to social media.

Review

NIST SP 800-53 is a resource that's designed to help organizations address data privacy risks. The document defines security controls, describes implementation strategies, and suggests individual control enhancements. AC-6 is a section about access controls that relate to the principle of least privilege.

Recommendation(s)

Based on the suggestion of NIST SP 800-53: AC-6, the data leak might have been avoided with the following controls:

- *Automatically revoke access to information after a period of time.*
- *Regularly audit user privileges.*

Justification

Automating security tasks whenever possible is a good way to reduce the chances of human error. In this case, creating a policy that sets expiration dates for access links might have avoided the leak. Requiring managers to regularly audit who can access their files is another way that information could be kept private.